Q What is Black Duck's place in the open source world?

Use of open source continues to increase rapidly worldwide because it helps organisations lower their development costs and deliver solutions faster. This is true for internal application development and for bringing commercial software to the market. To fully capitalise on the economic and productivity benefits that open source enables, leading organisations take steps to make sure their open source deployments are secure and well managed. One management challenge they face is ensuring that open source licence obligations are understood and met. The bigger and more important challenge today is making sure there is good visibility into the open source in use, so that the organisation can control the risks. This means making sure there is a comprehensive inventory of all the open source software being used and that it is mapped to security databases to detect any known security vulnerabilities.

This is where Black Duck fits in. We help our customers automate the processes of securing and managing the open source software they use to build their applications. Black Duck automates the open source identification and inventorying processes and we map the inventory–from the bill of materials to security databases, to find any known vulnerabilities. We also monitor the inventory constantly and if a new vulnerability is discovered, our customers receive a notification right away.

This approach enables our customers and partners to use open source software and services in the most secure, compliant and reliable way.

Q How does Black Duck secure open source deployments?

Software development teams are laser focused on getting solutions to market as quickly as possible. This fast-paced development approach often means that some of the open source code included in a project doesn't get properly recorded, or isn't recorded at all. When that happens, it becomes impossible to track the open source software. Almost every time Black Duck does an automated scan of a customer's code and creates an inventory, we find open source software that many in the organisation didn't know they were using. A recent study of 200 open source code audits we conducted showed an average of 50 per cent more open source software in the inventory than customers thought they had. So, by making it easy for development teams and organisations to identify, manage and secure the open source software they use, we help them reap the benefits of open source while controlling security and the associated risks.

Q What are the significant challenges in securing and managing open source software and how are they resolved by Black Duck?

The primary challenge in securing and managing open source software is creating and maintaining an accurate inventory of what you're using. Application developers pull anywhere from 75 to 125 open source components into an app; so without an automated process for inventorying and tracking them, managing these components over the lifecycle of the product is both difficult and prone to error. When you have 40 or 50 software developers, you can easily see how difficult it gets to find and fix potential open source issues without an automated inventorying process. As we've seen with recent, high-profile breaches in open source – HeartBleed for example – it is essential to be able to find and fix vulnerabilities. Of course, you can't cure what you can't see.

> "Some of the biggest and the most important companies in the world are developing software in India, so it's a natural fit for Black Duck to be here"

Black Duck tracks and collects data on about 1.7 million open source projects. We 'fingerprint' those projects, which enables us to provide our clients with an accurate open source inventory and to map any known vulnerabilities by scanning their code.

There are other ways to approach the inventorying task. For example, you can use a build manager or a package manager, which reports that the build you are calling has certain pieces and, based on those pieces, makes an estimate of the open source components in your software. This approach is hardly comprehensive and cannot be entirely accurate.

Incredibly, even though this is 2016, some companies still rely on Excel spreadsheets to keep track of open source software. Developers create, update and maintain the inventory manually. This is nearly impossible to keep current, and also requires that